Week 7

Software Project Risk Management

Identify uncertainty, prioritize exposure, plan responses, and monitor risk throughout the software project life cycle.

RISK ≠ PANIC

Risk management is structured decision-making under uncertainty.

Dr. Amr Mansour

Where Week 7 Fits in the Course

From approved plans to uncertainty-aware plans



What we already know

Scope, effort, schedule, resources, budget.

What Week 7 adds

What might happen? How serious would it be?

Why it matters

A baseline without risk treatment is only a best-case plan.

Learning Outcomes

By the end of this lecture, students should be able to...

1. **Distinguish uncertainty terms**
   Risk vs issue vs assumption vs constraint
2. **Identify software project risks**
   Using structured techniques and an RBS
3. **Analyze & prioritize**
   Probability, impact, exposure and P–I matrix
4. **Plan responses**
   Avoid, mitigate, transfer, accept; opportunity responses
5. **Build a risk register**
   Owner, trigger, response, contingency and status
6. **Monitor risks**
   Review exposure, convert realized risks to issues

Warm-up: The Plan Is Approved. Are We Safe?

Think–Pair–Share

ABC Retail has scope, estimate, schedule, resources and budget

Known Plan

6-month target
Payment gateway integration
2 developers + BA
Approved budget
External provider dependency

Question

Name THREE events that could change the project outcome even if the plan itself is correct.

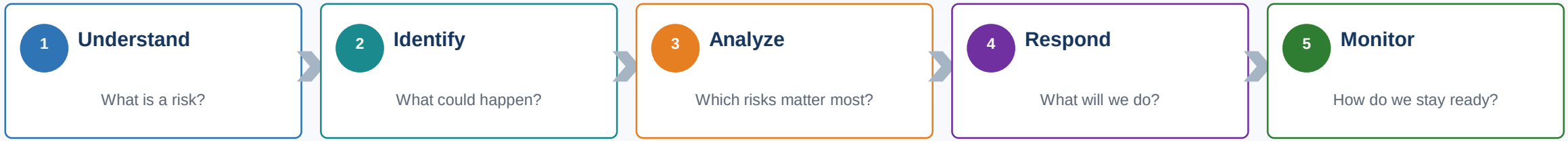
Then Ask

Which event deserves management attention first—and why?

A project plan describes what we intend to do. Risk management prepares us for what may actually happen.

Today's Roadmap

Five questions drive the lecture



Lecture pattern: Concept → ABC Retail example → Student problem → Solution → Semester-project connection

PART 1

Understanding Project Risk

Before managing risk, separate uncertainty from facts, limits and assumptions.

Why Software Projects Contain Uncertainty

Even a detailed plan cannot eliminate uncertainty

Requirements

Users discover needs after seeing working software.

Technology

APIs, frameworks, environments and integrations may behave differently than expected.

People

Availability, learning curves and communication vary.

External Context

Vendors, regulation, market timing and infrastructure can change.

Risk management does not ask “Can uncertainty be removed?” It asks “Can uncertainty be understood and managed before it becomes damage?”

Risk vs Issue vs Assumption vs Constraint

These four are often confused

Term	Meaning	ABC Retail Example
Risk	Uncertain event or condition that may affect objectives	Payment provider may delay API access
Issue	A problem that has already happened	API access is already 3 weeks late
Assumption	Something treated as true for planning	Existing customer data is accurate enough to migrate
Constraint	A fixed limit or restriction	Launch must occur before annual sales season

Key test: A risk contains uncertainty. An issue is already real.

Quick Check: Classify Each Statement

30 seconds

Statement 1

The selected cloud service may increase its price next quarter.

Statement 2

The approved budget cannot exceed 900,000 EGP.

Statement 3

The product database is assumed to remain available during migration.

Statement 4

The payment API documentation arrived two weeks late.

Classify each as Risk / Constraint / Assumption / Issue.

Risk Can Be Negative or Positive

A risk is uncertainty—not automatically a threat

Threat

An uncertain event that could harm project objectives.

Examples:
• Key developer becomes unavailable
• API delivery slips
• Security defect causes rework

Opportunity

An uncertain event that could improve project objectives.

Examples:
• Vendor releases reusable integration kit
• Automation reduces testing effort
• Experienced specialist becomes available

Professional risk management manages both downside and upside uncertainty.

Common Software Project Risk Categories

Categories help teams search systematically

Technical

Architecture, integration, performance, security

Requirements / Scope

Volatility, ambiguity, scope creep

Schedule

Dependency delays, unrealistic deadlines

Cost

Underestimation, inflation, extra licenses

People / Resource

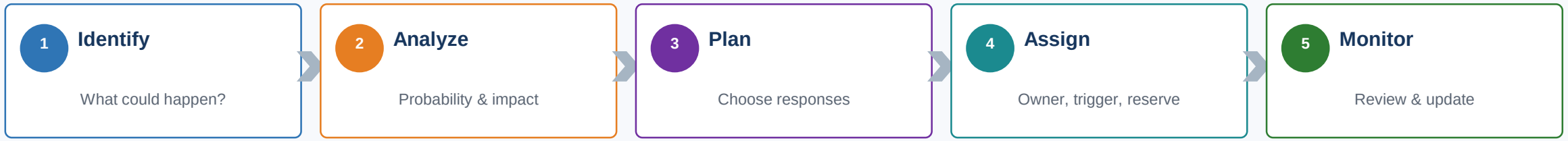
Availability, turnover, capability gaps

External / Business

Vendor, regulation, customer adoption

The Risk Management Cycle

Risk management is continuous, not a one-time document



New risks appear as the project changes → repeat the cycle.

PART 2

Risk Identification

Good analysis starts with good risk statements. Find uncertainty before it finds you.

When Should Risks Be Identified?

Not only at the beginning

1

Initiation

Business case assumptions, sponsor commitment

2

Planning

Scope, estimate, schedule, resources, vendors

3

Execution

New technology, defects, team availability

4

Change

New request creates new uncertainty

5

Closure

Acceptance, handover, unresolved obligations

A risk register is a living management tool, not a Week 7 assignment that is never opened again.

Techniques for Identifying Risks

Use multiple lenses to reduce blind spots

Brainstorming

Team-generated possibilities

Interviews

Experts, sponsor, users, vendors

Checklists

Known software risk patterns

Lessons Learned

Risks seen in previous projects

WBS / Schedule Review

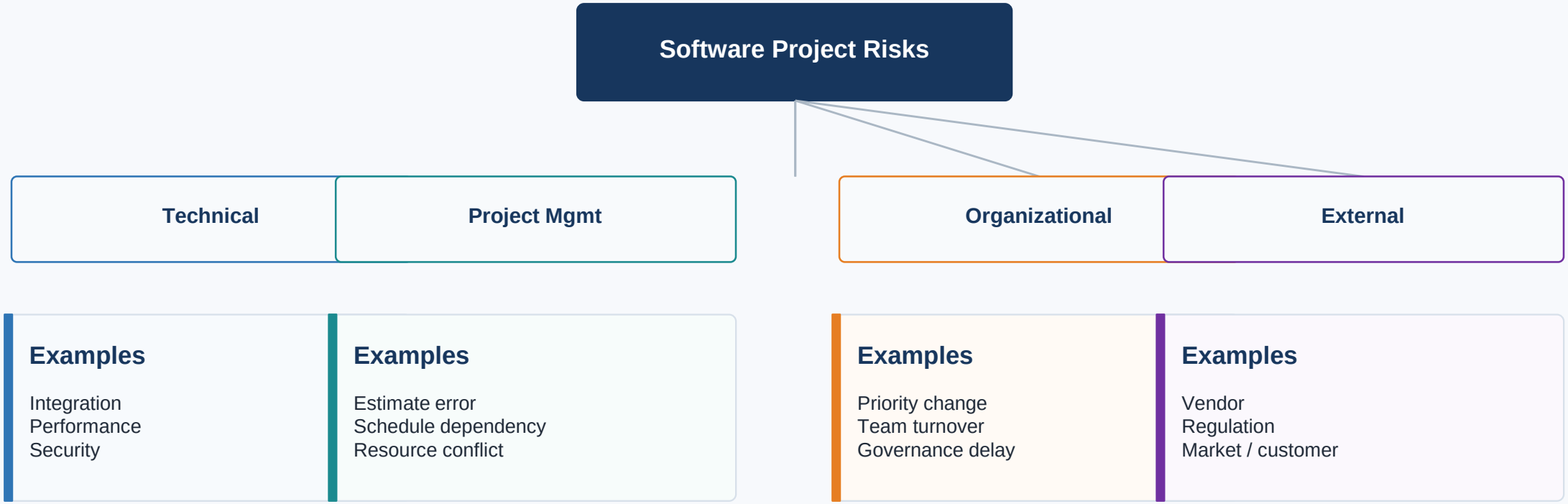
Look at complex or dependent work

Assumption Analysis

Ask: what if this assumption is wrong?

Risk Breakdown Structure (RBS)

A hierarchy of risk sources



RBS improves coverage: it helps the team ask “Where else could uncertainty come from?”

Worked Example: ABC Retail Risk Search

Worked Example

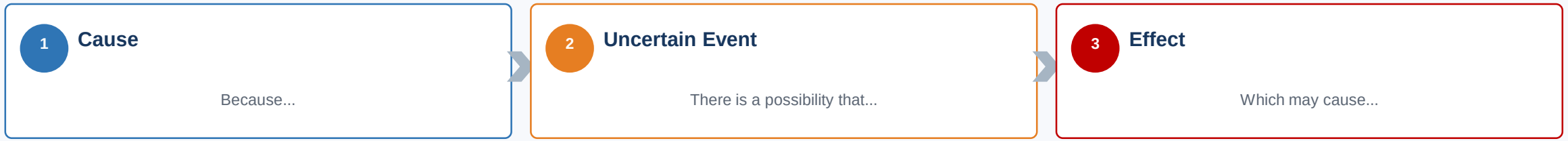
Use the plan to generate risks

Plan Element	Question	Possible Risk
Payment gateway	What do we depend on externally?	Provider may delay API access
2 Java developers	What happens if a specialist is unavailable?	Key developer may leave or become unavailable
6-month target	Which dates have little flexibility?	Integration/rework may push launch past sales season
Customer data	What assumptions could be wrong?	Migration data may contain missing or inconsistent records
New online channel	What business behavior is uncertain?	Customer adoption may be below forecast

Notice: each risk came from an existing project decision, dependency or assumption.

Write Risks as Cause → Event → Effect

Specific statements are easier to manage



Because the payment provider has not finalized its integration documentation, there is a possibility that API access will be delayed, which may postpone checkout testing and the planned launch date.

Poor Risk Statements vs Strong Risk Statements

Too Vague

“Payment risk”
“Schedule may fail”
“Developer problem”

Why weak? No event, no cause, no consequence.

Actionable

“The provider may delay API access, causing checkout integration and testing to start late.”

Why strong? A manager can assign an owner, trigger and response.

A good risk statement should make the next management action obvious.

Student Problem: Rewrite These Risks

2 minutes

Use Cause → Event → Effect. Make each risk specific enough to assign an owner.

Risk A

“Security problem”

Context: team has no payment-security specialist.

Risk B

“Users may complain”

Context: warehouse updates stock only once per day.

Risk C

“Schedule risk”

Context: API documentation is expected next month.

Write one complete risk statement for each.

Solution: Stronger Risk Statements

Solution

A — Security

Because the team lacks payment-security expertise, integration vulnerabilities may be missed, causing rework or acceptance failure.

B — Inventory Accuracy

Because stock is updated only daily, customers may order unavailable items, causing cancellations and dissatisfaction.

C — Schedule

Because API documentation is not yet available, integration may start late, delaying checkout testing and launch.

Different wording is acceptable if the statement clearly identifies an uncertain event and its consequence.

The Risk Register: Minimum Useful Fields

The register turns uncertainty into assigned management work

ID / Category

Trace and group risks

Risk Statement

Cause–event–effect

Probability

How likely?

Impact

How serious?

Owner

Who monitors and acts?

Response

What will we do?

Trigger

What tells us action is needed?

Status / Review

Open, watch, closed, escalated

Worked Risk Register: ABC Retail

Worked Example

A register should support decisions, not just record text

ID	Risk	P	I	Owner	Response	Trigger
R1	Payment API access delayed	4	5	Tech Lead	Mitigate	Docs not received by 15 Nov
R2	Key developer unavailable	3	4	PM	Mitigate	>3 days absence / resignation notice
R3	Migration data inaccurate	3	4	BA	Mitigate	>5% validation errors
R4	Customer adoption below target	2	3	Sponsor	Accept / enhance adoption plan	Pilot signup <20%

Next question: Which risk deserves attention first? → We need analysis and prioritization.

PART 3

Risk Analysis & Prioritization

Not every risk deserves the same management effort.

Qualitative Risk Analysis

Fast prioritization using probability and impact

Probability

How likely is the uncertain event to occur?

Use a consistent scale.

Impact

How strongly would it affect cost, schedule, scope, quality or value?

Priority

Combine probability and impact to focus management attention.

Qualitative analysis is relative. The team must agree what “High” probability and “High” impact mean before scoring.

Example Probability Scale

Define the scale before scoring

Score	Label	Example Interpretation
1	Very Low	≤10%
2	Low	11–30%
3	Medium	31–50%
4	High	51–70%
5	Very High	>70%

Exact thresholds may differ by organization. Use one agreed scale consistently.

Impact Is Multi-Dimensional

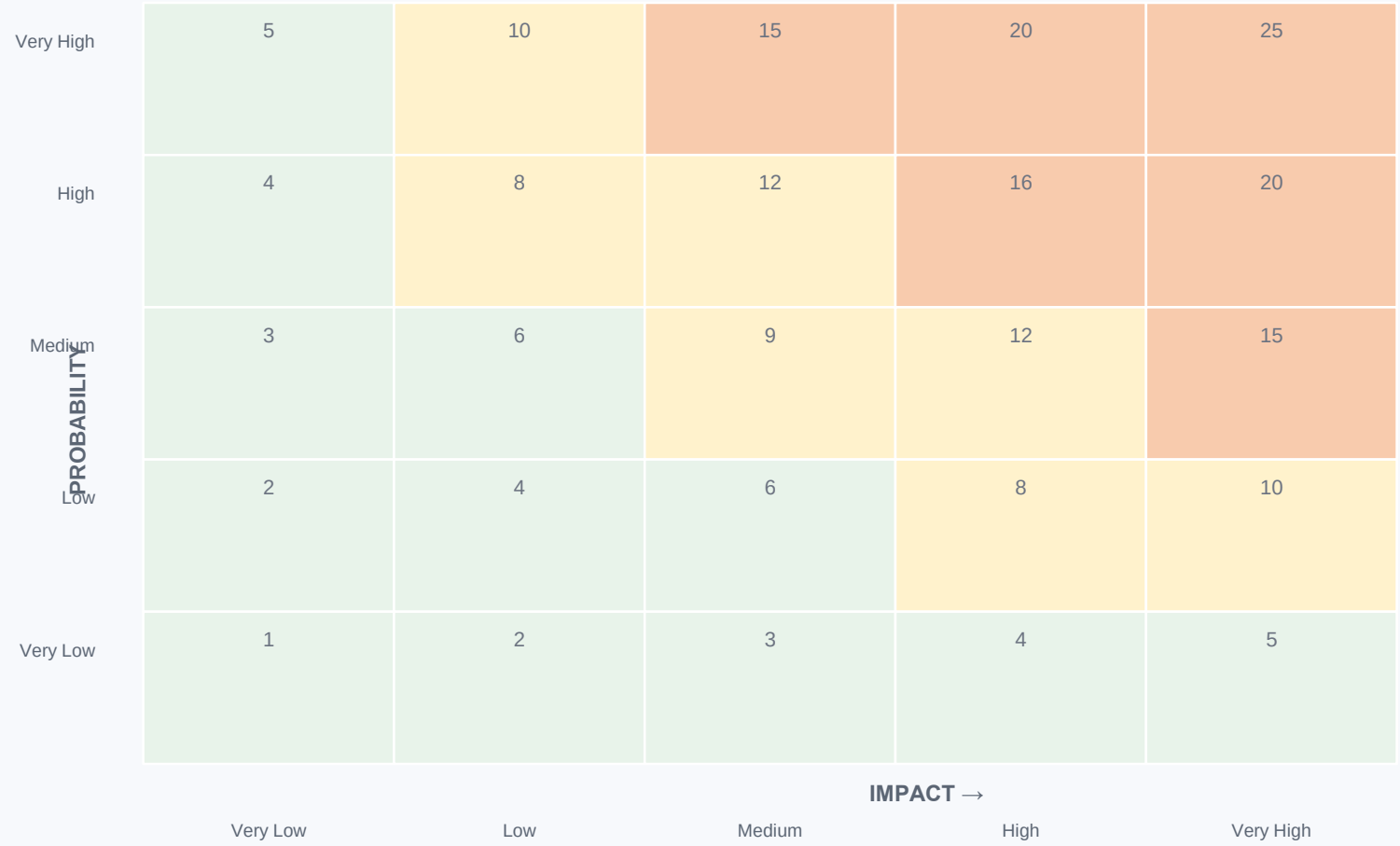
A risk can harm more than one objective

Impact Level	Schedule	Cost	Scope / Quality
1 — Very Low	<2 days	<1% budget	Negligible
2 — Low	2–5 days	1–3%	Small workaround
3 — Medium	1–2 weeks	3–7%	Noticeable rework / feature impact
4 — High	2–4 weeks	7–15%	Major rework / acceptance concern
5 — Very High	>4 weeks	>15%	Major objective or release threatened

For one risk, use the most relevant impact dimension—or the highest justified impact when several objectives are affected.

Probability–Impact Matrix

Visualize priority



Green

Monitor / accept where appropriate

Amber

Plan treatment and review

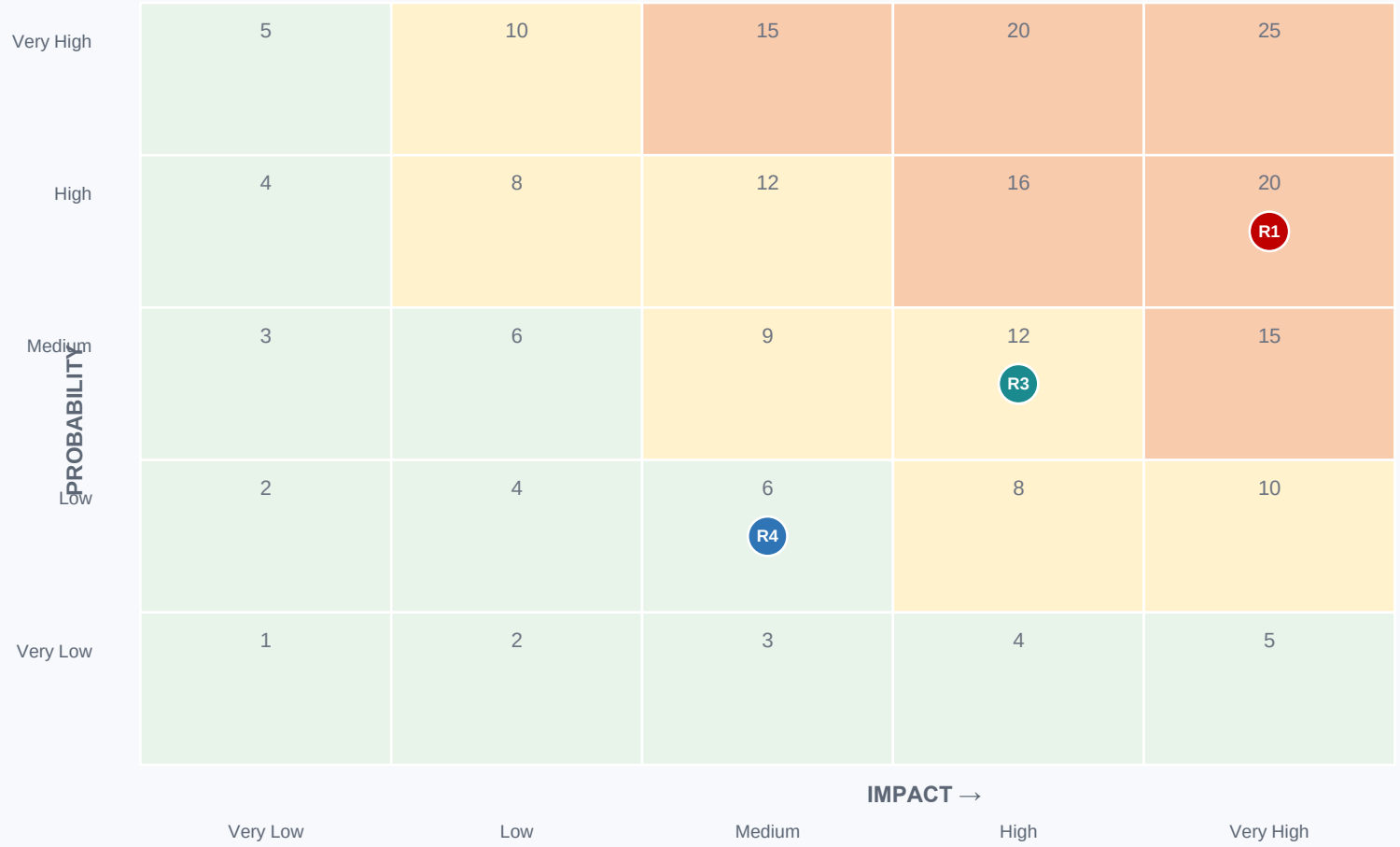
Red

Immediate management attention

Worked Example: Plot ABC Retail Risks

Worked Example

Same register, now prioritized



R1 = 20

Payment API delay → highest priority

R2 / R3 = 12

Important, treatment required

R4 = 6

Lower current priority, continue monitoring

Student Problem: Prioritize Smart Clinic Risks

3 minutes

Calculate P × I, rank the risks, then identify which one needs immediate response planning.

Risk	Probability	Impact	Score
R1: SMS provider delay	4	3	?
R2: Doctor schedule data inaccurate	3	4	?
R3: Key developer unavailable	2	5	?
R4: Users request extra reports	3	2	?

Rank highest → lowest. If scores tie, what else should influence your decision?

Solution: Smart Clinic Risk Priority

Solution

Risk	P × I	Priority	Comment
R1: SMS provider delay	4 × 3 = 12	High	External dependency; monitor trigger date
R2: Schedule data inaccurate	3 × 4 = 12	High	Could cause migration/rework and trust problems
R3: Key developer unavailable	2 × 5 = 10	High / Medium	Lower likelihood but severe consequence
R4: Extra report requests	3 × 2 = 6	Medium	Manage scope and change process

A tie is not a problem: management judgment breaks the tie using urgency, exposure window and response feasibility.

Risk Exposure (Expected Loss)

A simple quantitative view of threat magnitude

Risk Exposure (RE) = Probability × Loss if the risk occurs

Example

40% chance that API delay causes 80,000 EGP additional cost.

Calculation

RE = 0.40 × 80,000
= 32,000 EGP

Interpretation

Expected exposure helps compare risks and response economics.

RE is not a guaranteed future cost. It is an expected-value decision aid.

Worked Example: Compare Two Risks by Exposure

Worked Example

Risk	Probability	Loss if Occurs	Risk Exposure
A: Payment API delay	0.40	80,000 EGP	32,000 EGP
B: Key developer leaves	0.15	180,000 EGP	27,000 EGP

Risk A has the higher expected exposure even though Risk B has the larger single-event loss. Probability matters.

Student Problem: Calculate Risk Exposure

90 seconds

Which risk has the highest expected exposure?

Risk	Probability	Loss if Occurs	RE
R1: Security rework	0.25	120,000 EGP	?
R2: Data migration error	0.50	50,000 EGP	?
R3: Vendor delay	0.30	100,000 EGP	?

Calculate all three before ranking.

Solution: Risk Exposure

Solution

Risk	Calculation	RE	Result
R1 Security rework	0.25 × 120,000	30,000 EGP	Highest (tie)
R2 Migration error	0.50 × 50,000	25,000 EGP	Lower
R3 Vendor delay	0.30 × 100,000	30,000 EGP	Highest (tie)

Equal exposure does not mean equal response. Consider urgency, detectability, strategic impact and treatment cost.

Do Not Treat Risk Scores as Perfect Mathematics

Models support judgment—they do not replace it

Score Uncertainty

Probability and impact estimates can be wrong.

Dependencies

Two risks may be correlated rather than independent.

Timing

A risk next week may deserve attention before a larger risk six months away.

Use scores to structure conversation. Use managerial judgment to make the decision.

When Is Quantitative Analysis Worth the Effort?

Use more detail when uncertainty materially affects a major decision

Use It When

Large budget exposure
Critical deadline
High-impact vendor decision
Multiple uncertain estimates

Possible Tools

Expected Monetary Value
Decision trees
PERT / three-point estimates
Simulation in advanced settings

Avoid False Precision

Do not spend hours quantifying trivial risks with weak data.

The analysis effort should be proportional to the decision value.

Expected Monetary Value (EMV)

Compare uncertain decision alternatives

Option A — Build Custom Integration

70% chance cost = 60k
30% chance cost = 150k

Expected cost = 0.7×60 + 0.3×150 = 87k

Option B — Buy Connector

90% chance cost = 80k
10% chance cost = 120k

Expected cost = 0.9×80 + 0.1×120 = 84k

EMV suggests Option B has slightly lower expected cost—but reliability, schedule and strategic factors still matter.

PERT: Represent Uncertain Activity Duration

Three-point estimation converts uncertainty into an expected duration

$$\text{Expected Duration} = (O + 4M + P) / 6$$

Optimistic (O)

Best reasonable duration if things go well.

Most Likely (M)

Most realistic duration under normal conditions.

Pessimistic (P)

Long duration if plausible problems occur.

PERT is useful when activity duration itself is uncertain.

Worked PERT Example: Payment Integration

Worked Example

Estimates

O = 4 days
M = 7 days
P = 16 days

Calculation

TE = (4 + 4×7 + 16) / 6
= 48 / 6
= 8 days

Interpretation

Expected duration is longer than the most-likely estimate because downside uncertainty is substantial.

Do not confuse “most likely” with “expected.” PERT weights the three estimates.

Student Problem: PERT Under Uncertainty

90 seconds

For Smart Clinic user-acceptance testing: O = 3 days, M = 6 days, P = 15 days. Calculate the PERT expected duration.

Optimistic

3 days

Most Likely

6 days

Pessimistic

15 days

Expected duration = ?

Solution: PERT Expected Duration

Solution

$$TE = (3 + 4\times6 + 15) / 6$$

$$= 42 / 6 = 7 \text{ days}$$

Most Likely = 6 days

What the team expects under normal conditions.

PERT Expected = 7 days

Reflects the possibility of a much longer downside outcome.

PART 4

Risk Response Planning

A risk register is useful only when important risks lead to deliberate action.

Threat Response Strategies

Choose the response that best changes probability, impact or ownership

Avoid

Change the plan so the threat no longer applies
Example: Replace unstable API with approved provider

Mitigate

Reduce probability and/or impact
Example: Prototype integration early; add specialist review

Transfer

Shift financial/contractual responsibility
Example: Supplier warranty / insurance / fixed-price clause

Accept

Take no preventive action beyond monitoring / reserve
Example: Low exposure or treatment costs more than benefit

Escalate

Move beyond project authority
Example: Enterprise security/regulatory risk

Opportunity Response Strategies

Positive uncertainty also deserves deliberate action

Exploit

Make the opportunity happen
Example: Assign strongest developer to reusable automation

Enhance

Increase probability or positive impact
Example: Pilot new test automation early

Share

Partner with someone best placed to realize it
Example: Joint vendor integration accelerator

Accept

Take advantage if it occurs
Example: Use unexpected staff availability if it appears

Escalate

Pass to higher level if outside project authority
Example: Enterprise-wide platform opportunity

Worked Example: Choose a Response, Not a Label

Worked Example

Risk	Possible Response	Why
Payment API may be delayed	Mitigate: request sandbox access now + prototype using mock API	Reduces schedule impact and reveals integration problems earlier
Key developer may leave	Mitigate: code review, documentation, cross-training	Reduces single-person dependency
Low-value report may be requested	Accept + control via change process	Treatment effort may exceed exposure
Provider refuses contractual SLA	Transfer partly through contract / choose alternate supplier	Allocates financial responsibility or removes dependency

The response must describe an action. “Mitigate” alone is not a plan.

Contingency, Fallback and Reserve

What happens if the risk actually starts to materialize?

Contingency Plan

Pre-agreed action if a defined trigger occurs.

Example: if API docs are not received by 15 Nov, switch to mock service and parallelize UI testing.

Fallback Plan

Backup action if the main response or contingency is ineffective.

Example: switch to alternative payment provider.

Contingency Reserve

Budget/time held for known uncertainty.

Example: 10 extra integration days or approved risk reserve.

A response is preventive. A contingency is trigger-based. A fallback is the backup to the backup.

Every Important Risk Needs an Owner and a Trigger

Ownership turns analysis into accountability

Risk Owner

Accountable for monitoring the risk and ensuring the response is managed.

Trigger

Observable sign that tells the team risk likelihood or impact is changing—or contingency should start.

Action Owner

Person responsible for executing a specific response action. May differ from risk owner.

Example trigger: “Payment API documentation not received by 15 November.” This is measurable—“vendor looks slow” is not.

Student Problem: Plan the Response

4 minutes

Smart Clinic risk: The SMS provider may delay API access. P=4, I=3.

1 — Strategy

Avoid / Mitigate / Transfer / Accept / Escalate?

2 — Action

What exactly will the team do?

3 — Trigger

What measurable event starts contingency?

4 — Owner

Who should monitor it?

Also define one contingency plan.

Possible Solution: SMS Provider Delay

Solution

Field	Example Answer
Strategy	Mitigate
Preventive action	Request sandbox access now; build notification abstraction; test with mock service
Trigger	Production API credentials not received by 1 December
Risk owner	Technical Lead
Contingency	Switch to approved backup provider or temporary email notification channel

Many responses can be correct if they are feasible, specific and aligned with the risk.

Is the Response Worth It? Risk Reduction Leverage

Compare the exposure reduction with the cost of the response

Risk Reduction Leverage = (RE before − RE after) / Response Cost

Before

RE = 40,000 EGP

After Response

RE = 12,000 EGP

Response Cost

10,000 EGP

RRL = (40,000 − 12,000) / 10,000 = 2.8 → the expected exposure reduction is 2.8× the response cost.

PART 5

Risk Monitoring & Control

Risk management continues after the register is approved.

How Risks Are Monitored

Review exposure, triggers, actions and new uncertainty



Recommended practice: review top risks in every formal status meeting and after major changes.

When a Risk Happens, It Becomes an Issue

The management process changes

Before Occurrence — Risk

“The provider may delay API access.”

Manage with probability, impact, owner, trigger and response.

After Occurrence — Issue

“API access is 10 days late.”

Manage with issue owner, corrective action, due date, escalation and impact updates.

Do not leave a realized risk sitting in the risk register as though it were still uncertain.

Risk Must Connect to Schedule and Budget

A risk plan without reserved capacity may be impossible to execute

Schedule

Contingency time
Alternative sequence
Protected critical activities
Trigger dates

Budget

Contingency reserve
Response cost
Supplier protection
Rework allowance

Resources

Backup skill
Cross-training
Specialist access
Vendor escalation

This is why Week 7 follows estimation, scheduling and resource planning: risks modify the baseline assumptions.

Management Challenge: Limited Risk Budget

Decision Problem

You have only 30,000 EGP available for preventive risk responses. Which treatments should you fund?

Risk	RE Before	Response Cost	RE After
R1 Payment integration	45,000	12,000	15,000
R2 Data migration	30,000	8,000	18,000
R3 Key developer	40,000	20,000	22,000
R4 Low adoption	18,000	6,000	12,000

Do not choose only by the largest RE. Consider response efficiency, urgency and strategic importance.

Integrated Case: Smart Clinic Risk Workshop

5 minutes

Use the complete process

Risk 1 — Integration

SMS provider may delay API access.
P=4, I=3
Potential cost impact: 60k EGP

Risk 2 — Data

Doctor schedule data may contain inconsistent time slots.
P=3, I=4
Potential cost impact: 45k EGP

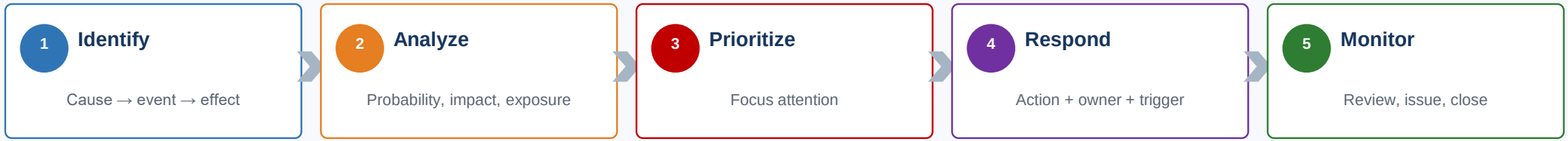
Risk 3 — People

Only one developer understands notification integration.
P=2, I=5
Potential cost impact: 100k EGP

For each risk: calculate P×I → choose response → define owner → define trigger. Then identify the TOP risk for management attention.

Week 7 Summary: From Uncertainty to Action

The complete risk logic



A mature project team does not promise “nothing will go wrong.” It demonstrates that important uncertainty has been identified, owned, treated and monitored.

Week 7 Practical Milestone — M7 Risk Baseline

Students apply today’s methods to the same semester project

1 — RBS

Create a project-specific risk breakdown structure.

2 — Risk Register

At least 8–10 meaningful project risks.

3 — Analysis

Probability, impact, score and priority.

4 — Response

Owner, strategy, action, trigger, contingency.

Then update your Week 5–6 schedule/budget assumptions where risk treatment requires time, money or resources.

Exit Quiz — 5 Questions

5 minutes

Answer individually, then compare with a partner

1. **What is the difference between a risk and an issue?**
2. Which has higher priority: P=4, I=3 or P=2, I=5?
3. What must accompany the word “Mitigate” to make it a real response plan?
4. What is the purpose of a risk trigger?
5. When a risk occurs, where should it be actively managed next?

References & Course Alignment

Primary academic alignment and practical extensions

Primary Textbook Alignment

Hughes, Cotterell & Mall — Software Project Management, Chapter 7: Risk Management.

Course Integration

Week 4 estimation
Week 5 scheduling
Week 6 resources & budget
Week 7 risk baseline

Practical Emphasis

Risk register
Probability-impact analysis
Response planning
Triggers, owners, contingency
Schedule/budget impact

Next milestone: integrate risks into the project baseline before the Week 8 Planning Gate Review.